

Adoption of the LGPD Inventory in the User Stories and BDD Scenarios Creation

Juliana and Saraiva

CIn/UFPE, Federal University of Pernambuco
julianajags@dcx.ufpb.br

Sergio and Soares

CIn/UFPE, Federal University of Pernambuco
scbs@cin.ufpe.br

ABSTRACT

Today's society heavily relies on intelligent technologies that capture and monitor real-time data, necessitating strong measures to ensure personal data privacy and protection. Regulatory frameworks like the General Data Protection Law (LGPD) in Brazil require software development to consider privacy throughout the software life cycle, significantly impacting the Requirements Engineering process. The LGPD mandates all companies to maintain a Personal Data Inventory (PDI) that records the flow of personal data from collection to disposal. This study investigates the feasibility of using the PDI in creating User Stories and Behavior-Driven Development (BDD) Scenarios, commonly used in requirements documentation for agile methodologies. Our research examines the correlation between PDI elements and User Stories/BDD Scenarios to assess their compatibility for representing and documenting software functionalities. The findings propose a mapping between these elements, supporting further research in Software Engineering and Information Security. The IDP shows promise in facilitating the construction of User Stories and BDD Scenarios and serves as a foundational reference for developing the PDI, a crucial legal document.

CCS CONCEPTS

• **Software security engineering**; • **Social network security and privacy**; • **Domain-specific security and privacy architectures**;

KEYWORDS

Inventário de Dados Pessoais, LGPD, Privacidade e Proteção de Dados, Engenharia de Requisitos Ágeis, Estórias de Usuário, Cenários BDD

ACM Reference Format:

Juliana and Saraiva and Sergio and Soares. 2023. Adoption of the LGPD Inventory in the User Stories and BDD Scenarios Creation. In *XXXVII Brazilian Symposium on Software Engineering (SBES 2023)*, September 25–29, 2023, Campo Grande, Brazil. ACM, New York, NY, USA, 6 pages. <https://doi.org/10.1145/3613372.3613375>

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than the author(s) must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.

SBES 2023, September 25–29, 2023, Campo Grande, Brazil

© 2023 Copyright held by the owner/author(s). Publication rights licensed to ACM.

ACM ISBN 979-8-4007-0787-2/23/09...\$15.00

<https://doi.org/10.1145/3613372.3613375>

1 INTRODUÇÃO

Uma vez que atual sociedade vive numa era onde tecnologias inteligentes de captação e monitoramento de dados em tempo real são utilizadas, o desenvolvimento de software precisa garantir a privacidade e proteção dos dados pessoais. Ademais, o avanço de soluções inteligentes através de conexões de dispositivos IoT imersos na vida das pessoas, aumentaram massivamente a coleta, compartilhamento e processamento de dados pessoais.

Levando em consideração que esses dados fazem parte da identidade e autodeterminação dos sujeitos, regulamentos sobre Privacidade e Proteção de Dados Pessoais vem sendo propostos ao redor do mundo, como é o caso da General Data Protection Regulation (GDPR) na Europa [1] e da Lei Geral de Proteção de Dados (LGPD) no Brasil [2].

Legislações como essas impõem que o desenvolvimento de produtos e soluções de software considerem a privacidade de dados pessoais desde a concepção e incorpore esta prática durante toda a vida do software: Princípios de *Privacy by Design* e *Privacy by Default* [3]. Esta obrigação impacta diretamente no Processo de Engenharia de Requisitos, que precisa se atentar à compreensão e documentação das funcionalidades, assim como às restrições do software sob esta perspectiva [4] [5]. Por outro lado, essas regulações exigem a criação de um Inventário de Dados Pessoais (IDP), que é um documento contendo o caminho que todos os dados pessoais percorrem desde o momento em que são coletados até o término do tratamento [6].

No Brasil, existe um órgão governamental – Autoridade Nacional de Proteção de Dados (ANPD) que é responsável por zelar pela proteção de dados pessoais através da regulamentação, implementação e fiscalização do cumprimento da LGPD [1]. Assim, a publicação de instruções normativas vem sendo realizada ao longo dos anos sobre a matéria de proteção e privacidade de dados pessoais.

Neste contexto, a ANPD publicou um guia para a construção do IDP, exigindo a presença de uma série de informações sobre o ciclo de vida do dado [6]. Algumas delas são: definição dos processos que tratam dados pessoais, os dados tratados, a categoria dos dados, qual base legal que fundamenta a utilização do dados, quais medidas de segurança da informação estão sendo adotadas para proteger os dados pessoais, dentre outras.

A construção do IDP é obrigatória em qualquer empresa brasileira que ofertar produtos e serviços com finalidade comercial, como é o caso das empresas de software. É importante ressaltar que essa exigência não é exclusivamente brasileira, aparecendo também em outras leis que tratam sobre privacidade ao redor do mundo, como a GPDR. Uma vez que ele é normalmente construído por uma analista de segurança da informação e não por engenheiros de software, há a necessidade de se investigar se as informações

contidas nele podem auxiliar a compreensão e especificação do sistema durante o processo de Engenharia de Requisitos.

Este estudo focou na avaliação de Metodologias Ágeis, considerando que elas são amplamente adotadas nos processos de desenvolvimento de software [7]. Dentre alguns dos artefatos gerados nas fases de compreensão dos software, Estórias de Usuário e Cenários BDD são utilizados para documentar os requisitos do sistema [8] [9]. Portanto, este trabalho tem como objetivo avaliar se o IDP pode ser utilizado para construção das Estórias de Usuários e Cenários BDD. Para isso realizou-se um estudo documental sobre o “Guia para a construção do Inventário de Dados Pessoais” publicado pela ANPD, a fim compreender os elementos obrigatórios do IDP e mapear essas informações com aquelas necessárias para construir Estórias de Usuário e Cenários BDD.

Este artigo é composto por sete seções, incluindo esta. A Seção 2 apresenta os trabalhos relacionados. O Inventário de Dados está explicado na Seção 3, enquanto as Estórias de Usuário e Cenários BDD podem ser compreendidos na Seção 4. A metodologia adotada neste estudo está apresentada da Seção 5 e a discussão dos resultados encontrada na Seção 6. Por fim, a Seção 7 expõe as conclusões e possibilidades de trabalhos futuros.

2 TRABALHOS RELACIONADOS

A junção de estudos nas Áreas de Engenharia de Software e Segurança da Informação está sendo bastante demandada nos últimos anos, uma vez que leis estão impondo a implantação de medidas de segurança às empresas de tecnologia para proteger a privacidade de dados pessoais. A PCM Tool: Privacy Requirements Specification in Agile Software Development, por exemplo, foi proposta como ferramenta para dar suporte à especificação de software [10]. Os autores pontuaram que os desenvolvedores de software possuem uma dificuldade em especificar requisitos de privacidade. Assim, eles propuseram essa ferramenta visando dar suporte a um guia, também proposto por eles, de especificação de requisitos de privacidade no desenvolvimento de software ágil.

Dando continuidade a este trabalho, o nível de compreensão dos desenvolvedores de software com relação à privacidade foi investigado [11]. Foram analisados fatores pessoais, comportamentais e do ambiente que poderiam influenciar no processo de tomada de decisão quando os requisitos de privacidade devem ser modelados. Através da replicação de entrevistas semiestruturadas com 30 engenheiros, 9 fatores pessoais, 5 comportamentais e 7 externos foram considerados relevantes para delimitar a compreensão e especificação dos requisitos de privacidade.

Também neste contexto, uma pesquisa bibliográfica sobre elementos do Scrum que podem ser utilizados para auxiliar as organizações na implantação da LGPD foi concluída [12]. Os autores alegam que adoção de Scrum proporciona maior agilidade e adaptabilidade às exigências legais. Além da LGPD, o investigou a importância de outras leis brasileiras, como o Marco Civil da Internet. Como resultado, os autores propuseram uma Metodologia Scrum como uma abordagem eficiente e versátil para a implantação e promoção da conscientização sobre a LGPD nas organizações.

Na mesma direção, um guia prático de adequação à LGPD foi desenvolvido para as empresas brasileiras [13]. A metodologia SGPD – Sistema de Gestão de Proteção de Dados foi apresentada para

gerenciamento de processos, implementação e governança de privacidade e proteção de dados. Como conclusão, foi observado que o framework Scrum demonstrou robustez em ferramentas e técnicas que facilitam o gerenciamento e implantação de cada uma das cinco fases do SGPD serve como guia de boas práticas para atingir o objetivo do projeto de implementação da LGPD.

No mesmo ano, o G-Priv foi proposto como um Guia para apoiar a especificação de requisitos de privacidade em conformidade com a LGPD [14]. Após a realização de um survey com 18 profissionais, como resultado, os autores propuseram um catálogo de padrões de privacidade e um guia - G-Priv, para auxiliar a especificação de requisitos de privacidade em conformidade com a LGPD.

É possível observar como soluções técnicas, métodos, artefatos e ferramentas de Engenharia de Software estão sendo adotados no processo de adequação à LGPD, na tentativa de tornar as empresas e os produtos em conformidade com a lei. Entretanto, estudos que analisem se os artefatos gerados pelos analistas em Segurança da Informação também podem ser adotados no processo de desenvolvimento do software ainda são demandados. Assim, o trabalho aqui proposto visa analisar se é possível utilizar o Inventário de Dados Pessoais (IDP) para dar suporte ao processo de Engenharia de Requisitos, especificamente focando na criação de Estórias de Usuário e Cenários BDD.

É importante pontuar, que apesar dos trabalhos mencionados tratem especificamente da LGPD, a tendência mundial de proteção dos dados apresenta-se de forma semelhante. Inclusive, a própria LGPD é uma inspiração da GDPR, vigente na Europa. Ressalta-se que a relevância desses trabalhos, assim como nosso, reforça a necessidade de comunicação de atividades multidisciplinares entre as áreas de Engenharia de Software e Segurança da Informação, a fim de prover a garantia da proteção e privacidade de dados pessoais, conforme impõem as leis e regulamentos ao redor do mundo.

3 INVENTÁRIO DE DADOS PESSOAIS (IDP)

O Inventário de Dados Pessoais LGPD (IDP) é um artefato que toda a instituição, pública ou privada, precisa construir e manter, caso realize tratamento de dados pessoais. Ele deve conter o registro das operações de tratamento de dados pessoais, conforme prevê o art. 37¹ da LGPD. É importante frisar que a expressão “Inventário de Dados Pessoais” não aparece na LGPD, pois ela é uma construção teórico-doutrinária para se referir ao registro das operações de tratamento de dados pessoais.

Segundo esta lei, “tratamento” é toda operação realizada com dados pessoais: coleta, produção, recepção, classificação, utilização, acesso, reprodução, transmissão, distribuição, processamento, arquivamento, armazenamento, eliminação, avaliação ou controle da informação, modificação, comunicação, transferência, difusão ou extração². Neste sentido, havendo qualquer processamento de dados pessoais na instituição, há a exigência da descrição e registro do tratamento no IDP³.

Uma vez que a LGPD não explicita quais informações precisam estar registradas no inventário, a Autoridade Nacional de Proteção

¹ Art. 37. O controlador e o operador devem manter registro das operações de tratamento de dados pessoais que realizarem, especialmente quando baseado no legítimo interesse.

² Art. 5º, X da LGPD. https://www.gov.br/governodigital/pt-br/seguranca-e-protecao-de-dados/ppsi/guia_inventario_dados_pessoais.pdf

³ Art. 5º, VIII da LGPD.

de Dados (ANPD) publicou um “Guia de Elaboração de Inventário de Dados Pessoais” com o objetivo de auxiliar esta construção. Ressalta-se que a criação do IDP objetiva-se atender não só a LGPD, mas também a outras normas vigentes que lidam com privacidade e segurança da informação.

Normalmente, o IDP é construído por analistas de segurança da informação ou advogadas(os), e mantido por encarregadas(os) de dados pessoais. Encarregada(o) é a pessoa indicada pelo controlador e operador para atuar como canal de comunicação entre o controlador, os titulares dos dados e ANPD. Não limitadas a essas, o IDP, obrigatoriamente, precisa conter:

1. Processo/Tratamento de dados pessoais;
2. Atores envolvidos (agentes de tratamento);
3. Titular dos dados pessoais;
4. Finalidade do tratamento;
5. Hipótese legal que embasa o tratamento (arts. 7º e 11 da LGPD);
6. Dados pessoais tratados;
7. Categoria dos dados pessoais;
8. Tempo de retenção dos dados pessoais;
9. Com quais instituições os dados pessoais são compartilhados;
10. Como é feita a transferência internacional de dados; e
11. Medidas de segurança da informação são adotadas.

Como é possível observar, várias informações que compõem o IDP podem ser utilizadas na compreensão e documentação do software. Requisitos funcionais, não-funcionais e de domínio, podem ser construídos através das informações contidas neste artefato de segurança da informação, mas que é pouco ou desconhecido pelos engenheiros de software. Portanto, investiga-se neste estudo se é possível a adoção do IDP, para que possa servir, ao menos como base, na construção dos artefatos gerados por engenheiros de software/analista de requisitos, no processo de Engenharia de Requisitos.

4 ARTEFATOS DA ENGENHARIA DE REQUISITOS ÁGIL

O Processo de Engenharia de Requisitos pode ser compreendido como um conjunto de atividades que lida com a identificação, análise, documentação e gerenciamento dos requisitos de um sistema ou software [15]. Neste contexto, diferentes modelos de processo adotam procedimentos distintos para sua realização, gerando, consequentemente, diferentes artefatos.

Neste cenário, as Metodologias Ágeis, há muito tempo, destacam-se no mercado de software como sendo algumas das mais proeminentemente adotadas [7], por causa da resposta rápida às mudanças, maior envolvimento do cliente, melhoria contínua, redução de riscos e foco na qualidade dos produtos gerados. Assim, este trabalho foca no estudo de dois dos artefatos gerados no processo de Engenharia de Requisitos abordado por algumas metodologias ágeis: Estórias de Usuário e Cenários BDD (*Behavior Driven-Development*).

A criação das Estórias de Usuário é uma técnica utilizada na Engenharia de Software que descreve requisitos funcionais vistos sob a ótica do usuário. Esta técnica é uma maneira concisa e simples de comunicar as necessidades e expectativas dos usuários em relação a um sistema ou software. Sendo elas escritas em linguagem natural,

fornece uma descrição breve e centrada na funcionalidade desejada pelo usuário, normalmente definidas seguindo uma sintaxe básica, através de 3 (três) cláusulas:

1. Eu **como** <ator/usuário/papel/função>
2. **Quero** <atividade/serviço - objetivo/meta>
3. **Para** <resultado/finalidade do processamento>

Já a construção dos Cenários BDD é uma estratégia usada no desenvolvimento de software para descrever o comportamento de um software ou funcionalidade, em termos do que se é observável [16]. Essa abordagem se concentra na colaboração entre desenvolvedores, analistas de negócios e partes interessadas para garantir um entendimento comum dos requisitos e comportamentos esperados. A construção de Cenários BDD auxiliam os engenheiros de software a validar se o sistema está funcionando corretamente e se atende aos requisitos esperados. Assim como as estórias, são escritos em linguagem natural apresentados de acordo com a estrutura a semelhança a seguinte:

1. **Dado** <pré-condições/contexto>
2. **Quando** <um (ou mais) evento ocorrer>
3. **Então** <saída obtida/comportamento esperado>

Para a construção das Estórias de Usuário e Cenários BDD várias informações precisam ser coletadas pelos engenheiros de software. Sob essa perspectiva, os Requisitos Funcionais (RF) normalmente são descritos através das Estórias, enquanto os Cenários BDD, focam no comportamento das funcionalidades, descrevendo Requisitos Não-Funcionais (RNF) e de Domínio. É importante destacar que os RNF normalmente são mais complexos de compreender, elicitar, documentar e validar, uma vez que possuem uma natureza mais abstrata, são mais conflituosos entre si para atender e de difícil medição [8] [9]. Visando auxiliar o processo de Engenharia de Requisitos, este estudo busca mapear elementos do IDP com as cláusulas-padrão que determinam as estruturas de construção das Estórias de Usuário e Cenários BDD, mostrados anteriormente.

5 METODOLOGIA

Uma vez que o IDP é um artefato necessário em toda instituição que oferta produto ou serviço de software, espera-se que informações contidas nele sirvam como pontapé inicial no Processo de Engenharia de Requisitos. A Figura 1 ilustra os passos metodológicos realizados nesta pesquisa documental. Primeiramente, foi realizada (a) uma análise documental da LGPD e do Guia de Elaboração de Inventário de Dados Pessoais publicado pela ANPD. Nesse guia foram analisados quais elementos obrigatórios deveriam compor o IDP.

Uma vez que a LGPD ainda é uma lei bastante principiológica, há a necessidade de complementos normativos para expressar de forma clara como ela deve ser aplicada. A ANPD vem publicando, há alguns anos, vários documentos como o Guia de Elaboração de Inventário de Dados Pessoais contendo instruções práticas acerca da implementação da LGPD. Assim, neste trabalho, ele foi a maior fonte de extração de dados nesta etapa.

Em seguida, foram (b) identificadas as cláusulas que podem ser adotadas para a construção das Estórias de Usuário e (c) para os Cenários BDD, conforme explicitado na Seção 3. Na sequência, (d) mapeou-se quais elementos que compõem essas cláusulas poderiam ser encontrados no IDP. Este mapeamento foi necessário porque

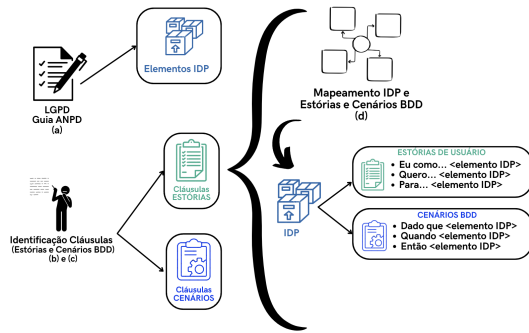


Figure 1: Ilustração dos Passos Metodológicos

o IDP é normalmente um documento extenso, com várias informações que não estão diretamente relacionadas com o processo de engenharia de requisitos, mas que é uma exigência normativa.

Apesar da ANPD não exigir um formato para sua construção, ele é elaborado geralmente em planilhas eletrônicas. Por mais simples ou pouca a quantidade de atividades de tratamento de dados pessoais numa instituição de desenvolvimento de software, essa planilha contém várias linhas (centenas ou milhares) - representando cada um dos dados pessoais utilizados em cada atividade - e várias colunas (dezenas ou centenas), contendo as informações (jurídicas e tecnológicas) a serem registradas sobre o dado pessoal, de acordo com a exigência da LGPD - os elementos do IDP.

Apesar do IDP contém informações que subsidiem a construção das Estórias e Cenário, sua utilização pode ser dificultada pelo seu tamanho, complexidade e mistura de informações técnicas jurídicas e de segurança da informação. Consequentemente, esquematizar onde os atores, descrição da funcionalidade, pré-condições e finalidade de execução podem ser encontradas no inventário, torna essa tarefas mais eficiente e rápida. Portanto, o mapeamento visa dar suporte à resolução do problema inspirado na forma como os computadores resolveriam - Pensamento Computacional (i) decompondo os problemas, (ii) abstraindo informações do IDP não úteis para a construção dos artefatos em Engenharia de Software, (iii) gerando pensamento algorítmico, e (iv) reconhecendo padrões a serem seguidos ao adotar o IDP.

Para apresentar didaticamente os resultados encontrados, adotou-se um cenário fictício de um Software de Controle Acadêmico (SCA) a ser desenvolvido, focando nas funcionalidades de “Cadastro de Usuário” e “Emissão de Histórico Escolar”. Este cenário foi escolhido porque há uma familiaridade dessas funcionalidades pela maioria dos SCA nos âmbitos de graduação e pós-graduação, tornando mais fácil a compreensão sobre um possível cenário real de aplicação.

A funcionalidade “Cadastro de Usuário” é um serviço no software que objetiva receber informações do usuário para sua persistência e serve como pré-requisito para acesso futuro ao sistema. Já a funcionalidade “Emissão de Histórico Escolar” caracteriza-se pela emissão, em formato .pdf, de um documento contendo informações escolares. O acesso a esta funcionalidade só é possível se o usuário estiver efetivado o login no sistema. Assim, observa-se que essa funcionalidade tem restrição de acesso e pré-condições existentes

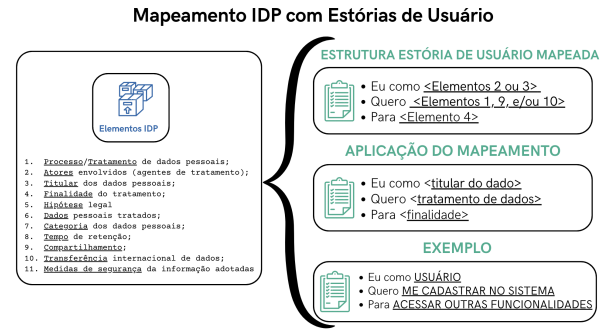


Figure 2: Mapeamento entre IDP e Estórias de Usuário

para sua execução: (i) existência de conta, (ii) efetivação de login no sistema, e (iii) finalização de componentes curriculares.

6 ADOÇÃO DE ARTEFATOS DA SEGURANÇA DA INFORMAÇÃO NA ENGENHARIA DE SOFTWARE

6.1 IDP para construção de Estórias de Usuário

Num cenário onde o IDP também descreve os processos do negócio que realizam o tratamento de dados pessoais, além do ciclo de vida desses dados quando tratados, a Figura 2 ilustra como os dados contidos no IDP podem ser utilizados na elaboração das Estórias de Usuário. É importante ressaltar que para este trabalho, as Estórias de Usuário são descritas conforme apresentado na Seção 3.

Como pode-se observar todos os elementos que preenchem as cláusulas na construção das Estórias do Usuário estão presentes no IDP. Os atores previstos nas Estórias são os Titulares dos dados pessoais (Elemento 2) ou os Agentes de tratamento (controlador ou operador - Elemento 3). A depender do sistema a ser desenvolvido, o Encarregado de dados pessoais, que também precisa estar identificado no IDP, pode ser um ator de uma Estórias de Usuário.

A funcionalidade que precisa ser descrita na Estória pode ser encontrada no IDP através da descrição do Processo de Negócio ou da descrição Tratamento de Dados (Elemento 1), da descrição do Compartilhamento - Interno, Externo ou Internacional (Elementos 9 e 10). Por fim, a finalidade da execução da funcionalidade descrita na Estória de Usuário pode ser obtida através da finalidade de tratamento descrita no IDP (Elemento 4).

6.2 IDP na construção dos Cenários BDD

Analogamente à construção das Estórias de Usuário, para construir os Cenários BDD, os engenheiros de software podem utilizar várias informações contidas no IDP. Levando em consideração a estrutura mostrada na Seção 3 para a elaboração dos Cenários BDD, a Figura 3 ilustra qual o resultado do mapeamento entre os artefatos de Segurança da Informação (IDP) e de Engenharia de Software (Cenários BDD).

Através da Figura 3 é possível compreender o contexto em que a funcionalidade será executada, ou seja, as pré-condições de operação, pode ser facilmente encontrado através das informações contidas no IDP sobre a Hipótese Legal, que autoriza o controlador

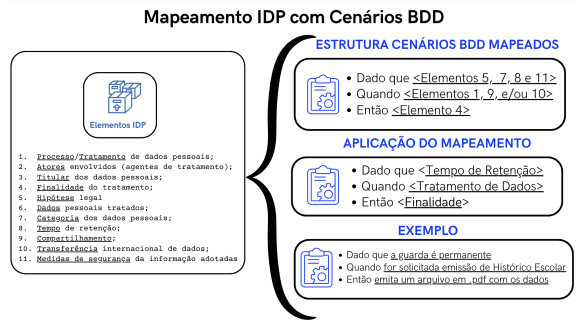


Figure 3: Mapeamento entre IDP e Cenários BDD

a realizar o tratamento (Elemento 5), a Categoria do dado pessoal – Comum ou Sensível (Elemento 7), o Tempo em que aquele dado pode ser retido, e consequentemente tratado (Elemento 9) e as Medidas de Segurança que precisam ser implantadas para o tratamento (Elemento 11). É importante deixar claro não há obrigatoriedade da presença de todos esses elementos na descrição do contexto, dependendo do caso concreto de funcionalidade a ser disponibilizada pelo software.

Para a cláusula do Cenário BDD que determina a execução da funcionalidade (<quando>), as informações sobre os diferentes tipos de tratamento e compartilhamento de dados pessoais podem ser encontradas através dos Elementos 1, 9 ou 10 do IDP. Novamente ressalta-se que todos esses elementos não estarão obrigatoriamente presentes nos Cenários BDD, ficando dependente do contexto em que a funcionalidade será executada. Por fim, a finalidade do tratamento (Elemento 4) pode ser utilizada para descrever o que acontecerá com o software ou com processo de negócio após a execução da funcionalidade (fluxo principal e fluxos alternativos).

6.3 Análise sobre o uso do IDP na Engenharia de Software

É visível a possibilidade de utilização do Inventário de Dados Pessoais (IDP), exigido pela LGPD, na construção das Estórias de Usuário e Cenários BDD. Todas as informações necessárias para suas elaborações, conforme cláusulas massivamente adotadas no processo de desenvolvimento de software (descritas na Seção 3) podem ser encontradas, através das descrições dos elementos do IDP mapeados. Este mapeamento visa facilitar o processo de Engenharia de Requisitos, fazendo com que requisitos não-funcionais, mais especificamente, de segurança da informação, ou de domínio, relacionado às hipóteses legais que permitem ou proíbam as empresas de software tratarem dados pessoais, sejam elicitados, documentados, validados e testados.

Ademais, medidas de segurança à nível de camada aplicação, onde geralmente encontra-se o desenvolvimento dos software numa estrutura computacional de distribuição de serviço tecnológico, serão levadas em consideração de forma mais sistemática. Isso pode acontecer devido à exigência da implantação dessas medidas conforme prevê o IDP, devendo ser abordadas explicitamente no processo de Engenharia de Requisitos – Princípio de *Privacy by default*.

Apesar de promissora a utilização do IDP na construção de Estórias de Usuário e Cenários BDD, conforme mostrado anteriormente, é importante deixar claro que há limitações. Os elementos do IDP restringem-se a cenários onde há necessariamente tratamento de dados pessoais. Uma vez que o Inventário LGPD só registra as operações ocorridas estritamente com esse tipo de dados – pessoais – outras funcionalidades e outros tipos de dados não estão descritos em Estórias ou Cenários a partir do IDP. Consequentemente, técnicas de levantamento de requisitos não podem ser excluídas desse processo.

Outro ponto importante quanto às limitações do uso restrito do IDP nesse processo é que não há a descrição detalhada sobre componentes de interface gráfica, nem fluxos de interação dos usuários com o software, fazendo com que técnicas de concepção de usuário, construção de personas e experiência do usuário sejam adotadas conjuntamente.

7 CONSIDERAÇÕES FINAIS

Levando em consideração as soluções tecnológicas cada vez mais inteligentes, coletando, compartilhando e processando dados, pessoais, regulamentos como a LGPD estão sendo adotados ao redor do mundo exigindo que a privacidade seja levada em consideração em todo o ciclo de vida do software. No contexto brasileiro, é obrigatório por lei que um Inventário de Dados Pessoais (IDP) seja construído e mantido por toda empresa de software. Uma vez que ele é normalmente construído por uma analista de segurança da informação, buscou-se investigar se as informações contidas nele podem auxiliar a compreensão e especificação do sistema durante o processo de Engenharia de Requisitos Ágeis.

Foi possível observar que ele pode ser utilizado no processo de especificação de requisitos ágeis, pelo menos como base para a criação de Estórias de Usuário e Cenários BDD. É importante ressaltar que essa exigência não é exclusivamente brasileira, aparecendo também em outras leis que tratam sobre privacidade ao redor do mundo, como a própria GDPR – “Registro de Atividades de Tratamento”.

Como implicações práticas para a Engenharia de Software é importante nos atentarmos que artefatos produzidos por outros profissionais nas empresas de software, podem ser adotados no processo de desenvolvimento de software. O IDP contém informações importantes sobre a proteção e privacidades de dados pessoais, que podem auxiliar os engenheiros de software na compreensão, elicitación e documentação de requisitos não-funcionais, como é o caso dos requisitos de privacidade e segurança.

Nesta perspectiva, em diversos cenários, o contato com usuário durante o processo de implantação da LGPD (pelos analistas de segurança da informação) ou de levantamento de requisitos (pelos engenheiros de software) é, muitas vezes, limitada. Logísticas de tempo, deslocamento, agenda podem ser fatores que influenciam a participação do usuário nesses processos. Desta forma, a adoção IDP, desenvolvido pela equipe de Segurança da Informação, pode ser uma alternativa, quando o usuário não puder participar do processo de desenvolvimento de software. Ou ainda, tanto o profissional de Engenharia de Software como o de Segurança da Informação podem promover encontros colaborativos com o usuário a fim de compreender e documentar os artefatos necessários para cada área de atuação na empresa.

Apesar da contribuição para Engenharia de Software, sabemos das limitações deste trabalho, demandando trabalhos futuros, como por exemplo avaliação da adoção de IDP por estudantes e profissionais de desenvolvimento de software. Um survey está sendo aplicado para saber a opinião dos profissionais de Engenharia de Software sobre o uso do IDP. Além disso, é necessário compreender se os artefatos da Engenharia de Software podem ser adotados pelos analistas de Segurança da Informação na construção do IDP. No Brasil, a proteção de dados pessoais tornou-se em 2020 direito fundamental, o que encabeça uma fiscalização e cobrança mais assertiva por parte das autoridades, no que diz respeito à segurança dos dados pessoais.

AGRADECIMENTOS

Este trabalho é parcialmente financiado pelo INES 2.0 (www.ines.org.br), bolsa CNPq 465614/2014-0, bolsas FACEPE APQ-0399-1.03/17 e APQ/0388-1.03/14, bolsa CAPES 88887.136410/2017-00. Sérgio Soares é parcialmente financiado pela bolsa CNPq 306000/2022-9.

REFERENCES

- [1] Lei Geral de Proteção de Dados (LGPD), Lei no. 13.709, de 14 de agosto de 2018.
- [2] General Data Protection Regulation (GDPR), Regulation (EU) 2016/679, 27 April 2016.
- [3] Alkubaisy, D., Piras, L., Al-Obeidallah, M.G., Cox, K. And Mouratidis, H. 2022. A framework for privacy and security requirements analysis and conflict resolution for supporting GDPR compliance through privacy-by-design. In Ali, R., Kaindl, H. and Maciaszek, L.A. (eds.). Cham: Springer [online], pages 67-87. Available from: https://doi.org/10.1007/978-3-030-96648-5_4
- [4] Senarath, A.R., Arachchilage, N.A.G., 2018b. Understanding user privacy expectations: A software developer's perspective. *Telemat. Inform.* 35, 1845-1862. <http://dx.doi.org/10.1016/j.tele.2018.05.012>.
- [5] Senarath, A., Grobler, M., Arachchilage, N.A.G., 2019. Will they use it or not? Investigating software developers' intention to follow privacy engineering methodologies. *ACM Trans. Priv. Secur.* 22, 1-30. <http://dx.doi.org/10.1145/3364224>.
- [6] ANPD. Guia de Elaboração de Inventário de Dados Pessoais. Brasília, DF: ANPD, [2023]. Disponível em: https://www.gov.br/governodigital/pt-br/seguranca-e-protecao-de-dados/ppsi/guia_inventario_dados_pessoais.pdf. Acesso em: May 01, 2023.
- [7] A Mihel A, Vrhovec S, Hovelja T. Agile development of secure software for small and medium-sized enterprises. *Sustainability*. 2023;15(1):801.
- [8] Georges T, *et al.* Guiding feature models synthesis from user-stories: an exploratory approach. *Synthesis*. 2023. 30:31.
- [9] Parsa S. Acceptance testing and behavior driven development (BDD). In: *Software Testing Automation: Testability Evaluation, Refactoring, Test Data Generation and Fault Localization*. Cham: Springer International Publishing; 2023. p. 79-158.
- [10] Peixoto, M., Silva, C., Lima, R., Araújo, J., Gorschek, T., & Silva, J. (2019). PCM Tool: Privacy Requirements Specification in Agile Software Development. In *Anais Estendidos do X Congresso Brasileiro de Software: Teoria e Prática*, (pp. 108-113). Porto Alegre: SBC. doi:10.5753/cbsoft_estendido.2019.7666
- [11] Peixoto, Mariana, *et al.* "The perspective of Brazilian software developers on data privacy." *Journal of Systems and Software* 195 (2023): 111523.
- [12] de Melo Filho DR, *et al.* Metodologia Scrum: Uma aliada na implementação da LGPD. *Research, Society and Development*. 2023;12(4):e22712441189-e22712441189.
- [13] Cardoso DL, Cardoso T. Adequação da LGPD via "Projetos Ágeis Scrum". *Boletim do Gerenciamento*. 2023. 35(35):28-41.
- [14] Camilio MN, Alves CF. G-Priv: Um Guia para Apoiar a Especificação de Requisitos de Privacidade em Conformidade com a LGPD. *iSys-Brazilian Journal of Information Systems*. 2023. 16(1):2-1.
- [15] Pohl K, Rupp C. *Requirements Engineering: Fundamentals, Principles, and Techniques*. Springer; 2015.
- [16] R Rose, S.; Wynne, M.; Helles, A. *The Cucumber for Java Book: Behaviour-Driven Development for Testers and Developers*. Birmingham: Pragmatic Bookshelf, 2015.